

Halden Distribution Ltd. — monitoring and incident readiness (executive brief)

To: Managing Director and management team · **From:** IT (Muhammad Ibrahim Akmal) **Date:** 2026-10-02 · **Subject:** what we can see, what we can respond to, and what we are asking you to approve
Length: 1 page · **Detailed plan:** [p07-ir-plan.md](#) · **Technical work:** P7 project documentation

The problem in one paragraph

Today, if someone attacked Halden, we would probably not know until the ransom note appeared. Logs live on each machine and overwrite within days; nobody watches them; and when the file server filled up last month, staff noticed before IT did. Ransomware appears in **88% of small-business breaches** (Verizon DBIR 2025) and attackers usually spend days inside a network before they encrypt — days in which a monitored environment can catch them and an unmonitored one cannot.

What we are building

A single place that watches the whole environment and a written plan for what to do when it fires:

- **Central monitoring (a SIEM)** — one system on a new server (SIEM01) that collects security events from every server and workstation, plus the firewalls. It looks for specific dangerous behaviours (new administrators, stolen credentials, ransomware preparation) rather than only known viruses.
- **Availability monitoring** — it also answers "is it down, or is it just me?" with a status page, and it watches the **backups**: if a backup does not report success, we are alerted, because a silent backup failure is how a company discovers it has no recovery.
- **An incident response plan** — severity levels, who decides what, who to call, and five written playbooks so the response does not depend on one person's memory at 3am.
- **A rehearsal (tabletop exercise)** — we will walk management and department heads through a realistic ransomware scenario, so the first time we deal with this is not the real thing.

What this means for the business

Risk today	After this project
An attack would be noticed only when it is too late	Dangerous behaviour raises an alert within moments
Nobody can answer "what happened, and when?"	A recorded timeline for every incident, built from real events
"Who do we call?" has no written answer	A severity matrix, an on-call route and a contact tree
A failed backup is found when a restore is needed	A missing backup heartbeat raises an alert
Staff ask "is it down?" by email and phone	A status page anyone can check

What we are asking management to approve

1. **The incident response plan** (`p07-ir-plan.md`) — severity definitions, roles, escalation and the external contacts (insurer, legal, regulator). The approval block is deliberately blank until you sign it.
1. **The monitoring policy** (`p07-monitoring-policy.md`) — what is logged, for how long, and the privacy commitments. Monitoring is for **security and availability, not for watching staff**.
1. **One tabletop exercise** (60 minutes) with management participation.
2. **The cost of the security simulator** — an authorised, isolated test we run on our own lab server to prove the alerts actually work. This requires the owner's explicit approval in writing before it is run, and it never touches anything outside our own lab.

What we need from you

Who	What	When
Managing Director	Approve the IR plan and the monitoring policy	Before go-live
Managing Director	Decide who is the management decision-maker during an incident	Before the tabletop
Department heads	Attend the 60-minute tabletop exercise	Scheduled together
All staff	Read the short monitoring notice (what is monitored and why)	On go-live

What this does not solve

No plan survives contact unchanged, and honesty matters more than reassurance: a small company cannot staff a 24×7 security team, so the response targets are best-effort. Detection is a safety net, not a guarantee, and we will measure how well it actually works rather than assume it. The results of the first test and the tabletop will be reported back to you with real numbers and any gaps found.

Decision requested: approve the incident response plan and the monitoring policy, and confirm participation in the tabletop exercise.

Halden Distribution Ltd. is a fictional company used for a home-lab portfolio project. The configurations, plan and measurements are real; the business scenario and named roles are simulated. Approval lines are unsigned until a real review happens.